Patient Health Records & Monitoring System

Reviewer: Mr Shehryar
System Architect: Eisha Nawaz (MSCS22007)
Threat Analyst: Affira Arif (MSCS24003)
Mitigation Engineer: Fatima Ijaz (MSCS25014)
Reporter: Arshiya khan (MSCS24009)
Generated: Thu Feb 12 2026



OWASP Threat Dragon

Executive Summary

High level system description

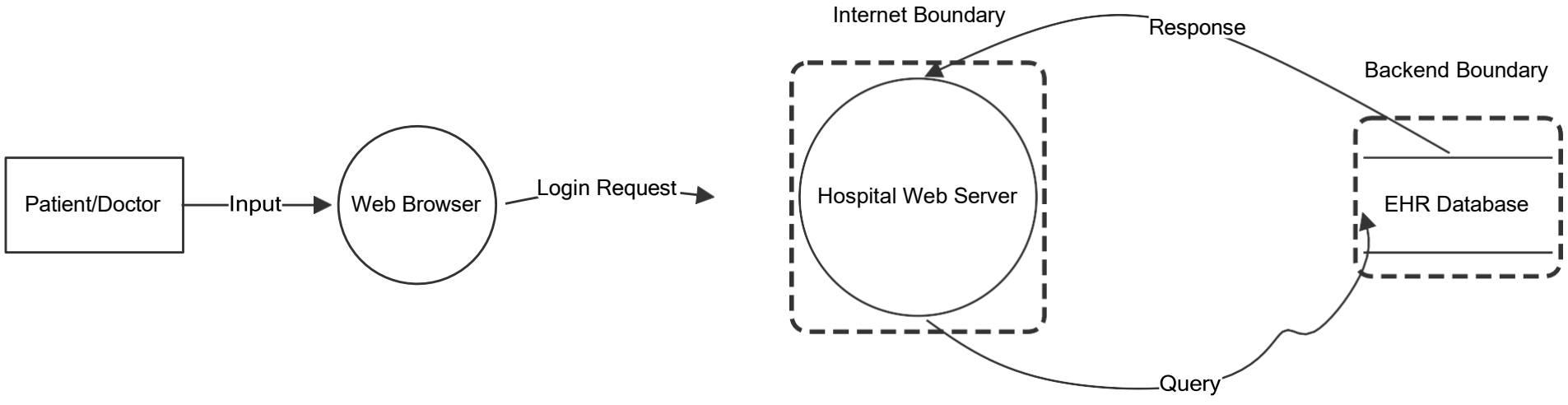
Web-based portal for doctors to view patient vitals, update prescriptions, and manage sensitive health records (PHI).

Summary

Total Threats	10
Total Mitigated	10
Total Open	0
Open / Critical Severity	0
Open / High Severity	0
Open / Medium Severity	0
Open / Low Severity	0

Architecture Diagram

An attacker impersonates a clinician or a patient to gain unauthorized access to the Hospital Information System.



Architecture Diagram

Patient/Doctor (Actor)

Properties:

Number	Title	Type	Severity	Status	Score	Description	Mitigations
1	New STRIDE threat	Spoofing	TBD	Mitigated		User credentials are stolen.	Implement Multi-Factor Authentication (MFA) using hospital-issued hardware tokens.

Hospital Web Server (Process)

Properties:

Number	Title	Type	Severity	Status	Score	Description	Mitigations
5	New STRIDE threat	Denial of service	High	Mitigated		A flood of requests crashes the hospital portal.	The primary mitigation is the deployment of a Web Application Firewall (WAF) combined with Rate Limiting at the network perimeter. The WAF acts as a shield, using behavioral analysis to identify and drop malicious traffic patterns—such as a botnet flooding the login page—before they reach the hospital's internal servers. Simultaneously, the server-side configuration should enforce strict rate limits (e.g., a maximum of 20 requests per minute per IP address). This ensures that even if an attacker attempts a "Low and Slow" attack, they cannot consume all available server threads. For a hospital, this is critical because it preserves "Availability," ensuring that legitimate medical staff can always access life-saving patient data even during a traffic spike.
6	New STRIDE threat	Elevation of privilege	Medium	Mitigated		A patient accesses the doctor's administrative dashboard.	To mitigate the threat of Elevation of Privilege on the Web Server, the system must implement a robust Server-Side Role-Based Access Control (RBAC) framework. Instead of relying on the client-side interface to hide administrative links, the server must independently verify the user's authorization level for every single request. When a user logs in, their assigned role (e.g., "Patient" or "Doctor") is embedded into a cryptographically signed JSON Web Token (JWT). Upon accessing the doctor's dashboard, a specialized middleware function on the server intercepts the request, decodes the token, and checks if the "role" claim matches the required permission for that specific endpoint. If a patient attempts to access a doctor-only URL, the server will detect the role mismatch and immediately terminate the request with an HTTP 403 Forbidden response. This ensures that even if a patient discovers a hidden administrative URL, the back-end logic prevents any sensitive data from being sent to an unauthorized account.
10	New STRIDE threat	Denial of service	Medium	Mitigated		An attacker sends thousands of large file upload requests (e.g., fake high-resolution MRI scans) to the server, filling up the temporary storage and crashing the portal for everyone else.	Implement File Size Limits and Request Rate Limiting specifically for the file upload endpoint.
11	New STRIDE threat	Elevation of privilege	High	Mitigated		A patient logs into their portal and notices their URL is hospital.com/records/105. They change the number to 106 and are able to view another patient's records because the server doesn't check if the user "owns" that ID.	Implement Object-Level Authorization checks; the server must verify that the UserID in the session matches the owner of the requested RecordID.

EHR Database (Store)

Properties:

Number	Title	Type	Severity	Status	Score	Description	Mitigations
4	New STRIDE threat	Information disclosure	High	Mitigated		Sensitive health records are leaked.	Implement AES-256 Transparent Data Encryption (TDE) for the EHR database files.
12	New STRIDE threat	Repudiation	Medium	Mitigated		A staff member makes an unauthorized change to a prescription and then accesses the system logs to delete the entry of their activity, leaving no evidence of the change.	Send logs in real-time to a Write-Once-Read-Many (WORM) storage or a remote Logging Server (like Syslog or ELK) where the hospital app does not have "Delete" permissions.

Input (Data Flow)

Properties:

Number	Title	Type	Severity	Status	Score	Description	Mitigations

Response (Data Flow)

Properties:

Number	Title	Type	Severity	Status	Score	Description	Mitigations

Login Request (Data Flow)

Properties:

Number	Title	Type	Severity	Status	Score	Description	Mitigations

Query (Data Flow)

Properties:

Number	Title	Type	Severity	Status	Score	Description	Mitigations
3	New STRIDE threat	Tampering	Medium	Mitigated		An attacker modifies the SQL query to view other patients' data.	Use TLS 1.3 with Certificate Pinning to prevent man-in-the-middle attacks.
9	New STRIDE threat	Tampering	High	Mitigated		Provide a description for this threaAn attacker inputs malicious SQL code into the "Patient Search" field. The server executes it, allowing the attacker to bypass the login or delete the entire Prescriptions table.t	Use Parameterized Queries (Prepared Statements) in the server-side code so user input is never treated as a command.

Web Browser (Process)

Properties:

Number	Title	Type	Severity	Status	Score	Description	Mitigations
8	New STRIDE threat	Information disclosure	High	Mitigated		Provide a descripA doctor leaves a terminal without logging out. A subsequent user (patient or visitor) clicks the "back" button and views the previous patient's lab results stored in the browser cache.tion for this threat	Set Cache-Control: no-store in HTTP headers and implement a 2-minute JavaScript-based inactivity timer that redirects to a logout page.